

Manager's Guide Information Security



Resilience System Design and Alignment to Standards

This resilience system has been designed by Risk and Strategic Management, Corp (RSM), a specialist company expert in designing and implementing complex resilience strategies which protect people, facilities, assets, information, operations and organizational reputation. This system has been aligned to the following ISO and BSI standards to ensure it reflects the professional standards and practices of High Reliability Organizations: ISO 31000: Risk management; ISO 22317: Business impact analysis; ISO 22301: Business continuity management; ISO 22320: Emergency management; ISO 34001: Security and resiliency; ISO 22316: Organizational resiliency; and BSI 17091: Crisis management.

Why is Information Security Needed

Effective information security ensures that no data is lost, stolen, or left unsecured – regardless of the sensitivity of the data. Any information that may cause harm or embarrassment to individuals, the organization, or external stakeholders by criminals, hostile governments, the media, militants or terrorists should be considered sensitive and should be appropriately protected. Specific examples of sensitive information include the following:

- Contract and financial information
- Operational plans and reports
- Organizational strategies
- External stakeholder information
- Business proposals
- VIP visits and activities
- Intellectual property
- Travel records and schedules
- Staff biodata and Next of Kin records
- Promotional and discipline reports
- Crisis and incident policies or reports
- Insurance documents
- Compensation packages
- Client meetings and events
- Investigations
- Security policies and plans

The risks from poor information security include:

- Theft, robberies, mugging and burglaries
- Assaults resulting in injuries or death
- Kidnapping and hostage taking
- Armed attacks
- Negative media attention
- Loss of competitive advantage and business
- Individual or organization embarrassment
- Legal and reputational risks
- Damages to employee morale
- Harm to external stakeholders

Management Responsibilities

Managers are responsible for ensuring that physical and procedural information security protocols are carried out by all staff and subcontractors to prevent data theft or loss. Failure to implement these measures may result in a breach of security. Information security effectiveness is based on:

- Limiting access to data by using layers of encryption and security protocols
- Implementing and enforcing a “clear policy”
- Securing physical data storage assets or hard copy information
- Reducing vulnerabilities which might enable data loss or theft
- Reporting breaches of security immediately
- Ensuring staff are appropriately trained and managed

Information security is based on:

Confidentiality	Integrity	Availability
Prevention of the disclosure of information to unauthorized individuals or systems.	Prevention of modification of systems or data storage without appropriate authorization.	Keeping the data and systems available for use by authorized persons.

Confidentiality

Data that is located in servers, databases, hard-copy folders, or visible on staff members’ desks or open areas should not be accessed by persons who do not have the right clearance, identification, and/or protection. Confidentiality includes:

- **Clearance:** Is a basis of protection based on levels of defense. This refers to how much data you are allowed to access and/or when you can access it. Individuals / systems that are given ‘higher’ clearance are allowed to access more data.
- **Identification:** Is a basis of showing that you have the correct clearance. It revolves around *something you know*, *something you have*, or *something you are*. An example of each of these are: *something you know*: “What is your mother’s maiden name?”, a PIN identification number, or a password; *something you have*: magnetic swipe, driver’s license; *something you are*: biometrics (e.g. retina scan, fingerprints, voice prints, etc.)
- **Protection:** There are two parts to protection: the *authorization* and the *identification*, [1] *Authorization* is most commonly seen as an assigned username or swipe card, and [2] *Identification* is a password or keyword assigned to that identification

A “breach” is where unauthorized persons access data. Manager must report a breach immediately and begin looking for the location of the breach in the system – that is the *point of entry* where the breach occurred. When you apply **clearance**, **identification**, and **protection** correctly, only authorized persons should have access to data.

Integrity

Integrity is based around the prevention of modification of data when a breach occurs. Password protecting data is a common method of increasing integrity. Other methods include logging of all changes to data and retention of these logs so that the extent and impact of any breach can be analyzed and mitigated. As with any kind of security, it is best implemented in tiers to maximize protection and minimize risk. A good systematic approach for the security of your office's IT systems to use a combination of policies and technologies including password protecting data, with limited file permissions (tailored to department/usability/availability), a high security firewall, data encryption, and an appropriate routing network.

Availability

Availability is comprised of virtual and physical availability – i.e. access to the systems electronically and the ability for storage or processing assets to be compromised. Though a full-lockdown of systems might be a completely secure, it would not be accessible. The availability of data is an opposing idea that needs to be balanced accordingly when you are constructing a network or general access to information. This requires allowing some freedom to users, but it should remain limited on an as required basis. Managers should apply layering of access – creating specific filing structures in a file server or SharePoint site which allows users access to only those areas required by their role – and thus restricting information on a *“need to know basis”*. This strategy should also be applied to stored hard copy data files such as personnel files, contractual and financial records, security policies and plans and office plans and sensitive reports.

Managers need to secure information by considering the application of:

- **Clear Desk Policy:** A “Clear Desk Policy” can limit the availability of information to unauthorized persons. Sensitive information can be locked away when not in use, especially overnight when cleaners may have unrestricted access to the facility. Personnel using sensitive data should be provided lockable cabinets or rooms where data can be secured. The desk policy for this office is:

Yes	No	Information Security Controls
		All sensitive materials are locked in desks at the end of the day
		A dedicated lockable cabinet / container is provided to secure information
		A dedicated room is provided to secure information

- **Securing Data:** Server rooms should be secured to prevent access and ideally have an alarm system fitted to alert managers of a breach. Flash-drives and other portable devices should be locked away or carried on the user’s person.
- **Traveling with Data:** Travelers should consider what information they require for the trip and whether the loss of any information may compromise individuals, the office or the organization. Staff should not store sensitive data on flash drives or external hard drives unless there are authorized to do so. Flash or external drives from others IT assets should not, unless approved, be connected to a work computer.

Data Loss and Disposal

Managers and staff must understand the correct process for disposing of data or removing the risks of data theft when equipment or documents are being disposed of, or transferred, to another office. Often IT assets retain sensitive data, even after staff believe they have sanitized the asset. The following measures will be taken during data disposal or where data thefts have occurred:

- **Data Theft:** If data or assets loss or theft occurs then staff and managers should immediately report the incident and provide a full list of the information stolen or lost so that a risk assessment can be conducted as to the potential implications of the loss. Any affected parties, including impacted internal and external stakeholders, should be notified. Police and or government agencies might also need to be informed. The same considerations are applied if data is believed to have been compromised. Data thefts are to be immediately reported to the headquarters office.
- **Erasing Data:** The Information Technology department is responsible for the disposal of all network devices, hard drives, flash drives, and computers to ensure the contents of these devices are thoroughly erased.
- **Disposing of Identities:** Identities as well as computers may be disposed of if compromised. These disposable identities prevent harassment by stalkers, giving the user the option of choosing who knows their new email identification.

- **Disposing of Hard Data:** Hard data files, paper and documents should be destroyed in a manner which protects the integrity of the information. This may be through the use of a shredder, or in the absence of a shredder, documents may be burned. In some areas, professional contracted companies can be used to safely dispose of data. These companies should be vetted before they are engaged.